

Q/CUP

中国银联股份有限公司企业标准

Q/CUP 046.6.1—2014

代替Q/CUP 041.1.1-2012

中国银联 IC 卡技术规范——辅助规范 第 6 部分 金融 IC 卡借记/贷记应用根 CA 公钥认证规范——管理规则

China UnionPay integrated circuit card specifications
—auxiliary specifications

Part 6 Financial IC Card Debit/Credit Applications Root CA Public Key
Authentication Specification——Management Specification

2014-11-30 发布

2014-11-30 实施

中国银联股份有限公司 发布

目 次

前 言	III
中国银联 IC 卡技术规范——辅助规范	1
1 范围	1
2 规范性引用文件	1
3 术语和定义	1
3.1 发卡机构标识代码 Bank Identification Number; BIN	1
3.2 EMV	1
3.3 入网机构标识码 institution identification code	1
3.4 成员机构 (Member organisation)	1
3.5 金融 IC 卡借记/贷记应用根 CA (Financial IC Card Debit/Credit Applications Root CA)	1
3.6 发卡机构 (Issuer)	2
3.7 收单机构 (Acquirer)	2
3.8 主账号 primary account number; PAN	2
3.9 RID, Registered application provider identifier	2
3.10 公钥密码算法 (Public key cryptographic algorithm)	2
3.11 哈希算法 (Hash algorithm)	2
3.12 静态数据认证, Static data authentication; SDA	2
3.13 动态数据认证, Dynamic data authentication; DDA	2
3.14 CDA, Combined dynamic data authentication/application cryptogram generation	2
4 金融 IC 卡借记/贷记应用公钥认证体系	2
4.1 金融 IC 卡借记/贷记应用公钥认证体系概述	2
4.2 根 CA 公钥认证服务	3
4.3 生产型公钥证书和测试型公钥证书	3
4.4 根 CA 机构角色	3
5 成员机构的公钥认证服务注册及管理	4
5.1 公钥认证服务注册	4
5.2 注册管理	5
6 根 CA 公钥证书的管理	5
6.1 根 CA 公钥证书的申请、验证流程	5
6.2 收单机构根 CA 生产型公钥证书的放置、移出	5
7 发卡机构公钥证书的管理	6
7.1 发卡机构公钥证书申请、传递、验证	7
7.2 发卡机构公钥证书申请前的准备	7
7.3 发卡机构对根 CA 签发的公钥证书的验证与接受	8
7.4 发卡机构公钥信息变更管理	8
8 根 CA 公钥认证体系安全策略的安全规则	8
8.1 一般规则	8
8.2 根 CA 规则	9
8.3 发卡机构规则	11

8.4 收单机构规则	12
附 录 A （规范性附录） 金融 IC 卡借记/贷记应用根 CA 安全策略的基本条款.....	13
A.1 责任与义务	13
A.1.1 银联公钥认证管理机构责任和义务.....	13
A.1.2 根 CA 责任和义务	13
A.1.3 发卡机构 CA 责任和义务	13
A.1.4 收单机构责任和义务.....	13
A.2 免责和理赔	13
A.3 信任体的责任关系	14
A.3.1 证书依赖方和证书持有者的赔偿责任.....	14
A.3.2 信托关系.....	14
A.4 解释和说明	14
A.4.1 监管法律.....	14
A.4.2 争端解决的程序.....	14
A.5 审计	14
A.5.1 对根 CA 的审计	15
A.5.2 对成员机构的审计.....	15
A.5.3 审计者的资质.....	15
A.5.4 审计者与被审计机构的关系.....	15
A.5.5 审计的主要内容.....	15
A.5.6 对不足的处理.....	15
A.5.7 审计结果.....	15
A.6 保密	15
A.6.1 保密信息.....	15
A.6.2 非保密信息.....	16
A.6.3 证书被废除/暂停使用的信息披露	16
A.6.4 向法律执行机关披露.....	16
A.6.5 根据所有者的要求披露信息.....	16
附 录 B 成员机构注册及安全管理员证书申请表	17

前 言

本标准对金融IC卡借记/贷记应用根CA公钥认证系统及服务在管理流程及安全策略方面的要求做了规定。

本标准由中国银联股份有限公司提出。

本标准由中国银联股份有限公司制定。

本标准起草单位：中国银联股份有限公司。

本次2014年对规范进行修订。

本标准主要起草人：刘先、徐晋耀、徐志忠、杨辅祥、李春欢、柏建宁、隆永红、赵宇、黄发国、姜红、赵改侠、朱露、汤洋。

中国银联 IC 卡技术规范——辅助规范

第 6 部分 金融 IC 卡借记/贷记应用根 CA 公钥认证规范

——管理规则

1 范围

本部分对金融IC卡借记/贷记应用根CA公钥认证管理规则及安全策略方面的要求做了规定。

本标准适用于金融IC卡借记/贷记应用根CA公钥认证的服务提供机构和服务接受机构,包括认证管理机构、接受认证服务的中国银联成员机构以及中国银联成员机构授权的代理机构。

2 规范性引用文件

下列文件中的条款通过本标准的引用而成为本标准的条款。凡是注日期的引用文件,其随后所有的修改单(不包括勘误的内容)或修订版均不适用于本标准,然而,鼓励根据本标准达成协议的各方研究是否可使用这些文件的最新版本。凡是不注日期的引用文件,其最新版本适用于本标准。

JR/T 0025 中国金融集成电路(IC)卡规范

JR/T 0003-2001 银行卡联网联合安全规范

《银联卡业务运作规章》第七卷《IC卡业务规则》,2005年
银联卡密钥安全管理规则,2004年8月

3 术语和定义

3.1

发卡机构标识代码 Bank Identification Number; BIN
用于标识发卡机构的代码。

3.2

EMV

EMV是EUROPAY、MasterCard、VISA三个国际信用卡公司的首字母缩略词,这三个公司联合制定的IC卡借记/贷记应用标准,简称为EMV标准。

3.3

入网机构标识码 institution identification code

在银行卡网络上唯一地标识受理方、发卡方、交换中心等机构的代码,通常用于ISO 8583报文中的下列数据元:

域32: Acquiring Institution Identification Code。

域33: Forwarding Institution Identification Code。

域99: Settlement Institution Identification Code。

3.4

成员机构 (Member organisation)

在本标准中指中国银联成员机构。

3.5

金融 IC 卡借记/贷记应用根 CA(Financial IC Card Debit/Credit Applications Root CA)

由中国人民银行授权建立的、由中国银联统一管理的服务于金融行业IC卡安全应用的根认证中心,以下简称“根CA”。实现该根认证中心功能的应用系统是“金融IC卡借记/贷记应用根CA系统”,以下简称“根CA系统”。

3.6

发卡机构(Issuer)

指开展金融IC卡发卡业务的成员机构。

3.7

收单机构 (Acquirer)

指开展金融IC卡收单业务的成员机构。

3.8

主账号 primary account number; PAN

标识发卡机构和持卡人信息的数字代码。它由发卡机构标识代码、个人账户标识和校验位组成，是银行卡金融交易的主要账号，在银行卡金融交易中等同于卡号。

3.9

RID, Registered application provider identifier

已注册的应用提供者标识。

3.10

公钥密码算法(Public key cryptographic algorithm)

《中国金融集成电路 (IC) 卡规范》第七部分第十二章规定的公钥密码算法。

3.11

哈希算法(Hash algorithm)

《中国金融集成电路 (IC) 卡规范》第七部分第十二章规定的哈希算法。

3.12

静态数据认证, Static data authentication; SDA

终端认证卡片中静态数据的签名，是脱机数据认证的一种。这种认证用于防止对卡片中关键个人化数据的篡改。

3.13

动态数据认证, Dynamic data authentication; DDA

芯片卡对特定交易数据元进行签名，终端验证该签名，是脱机数据认证的一种。这种认证用于防止卡片的非法复制、伪造。

3.14

CDA, Combined dynamic data authentication/application cryptogram generation

复合动态数据认证/应用密文生成，是脱机动态数据认证的一种。这种认证用于防止卡片的非法复制、伪造，同时生成交易密文。

4 金融 IC 卡借记/贷记应用公钥认证体系

4.1 金融 IC 卡借记/贷记应用公钥认证体系概述

金融IC卡借记/贷记应用公钥认证体系符合《中国金融集成电路 (IC) 卡规范》，为所有遵循该标准的金融IC卡借记/贷记提供公钥认证服务，也同时为其它金融IC卡数据认证提供途径（如成员机构终端提供的对外卡数据认证）。

按照《中国金融集成电路 (IC) 卡规范》，金融IC卡借记/贷记应用公钥认证体系包括根CA、各发卡机构CA及其发行的金融IC卡、收单机构及其ATM和/或POS。金融IC卡借记/贷记应用公钥认证系统使用公钥密码技术进行金融IC卡静态数据、动态数据或复合数据的生成及认证，以提供高度安全的金融IC卡交易认证服务。

—— 根 CA 负责生成根 CA 公私钥对并管理根 CA 的公私钥信息、签发发卡机构 CA 公钥证书，将根 CA 公钥信息安全传递给收单机构，是金融 IC 卡借记/贷记应用公钥认证体系的信任顶点。

- 各发卡机构 CA 是根 CA 的子 CA，负责生成发卡机构 CA 的公私钥对，向根 CA 申请并管理自己的公钥证书。此外，发卡机构 CA 与发卡系统交互，为 IC 卡签署静态应用数据以便进行静态数据认证(SDA)，或生成 IC 卡公私钥对、签发 IC 卡公钥证书以便进行动态数据认证(DDA)，同时将自己的公钥证书、IC 卡公钥证书、IC 卡私钥、RID、根 CA 公钥索引也写入 IC 卡。
- 收单机构负责建立终端管理系统，将根 CA 公钥分发到受理终端(POS/ATM)，并对远程终端进行设备管理、状态监控及信息管理(包括程序、参数下载)。

在《中国金融集成电路(IC)卡规范》标准卡支付系统中，IC卡存放IC卡公钥证书及IC卡私钥(或静态数据)和发卡机构公钥证书、RID以及根CA公钥索引；受理终端存放根CA公钥、公钥索引和相关的RID。

在支付过程中，受理终端通过验证IC卡的应用数据的签名进行IC卡数据认证，其过程是：首先读取IC卡内的RID、IC卡公钥证书、发卡机构公钥证书和根CA公钥索引，通过RID和根CA公钥索引定位特定的根CA公钥，通过根CA公钥验证发卡机构公钥证书，通过发卡机构公钥验证IC卡公钥证书，通过IC卡公钥验证IC卡内的动态签名或直接利用发卡机构公钥验证IC卡内的静态签名。整个IC卡数据认证完全离线进行。

金融IC卡借记/贷记应用公钥认证体系是一个独立的两层树状结构的PKI体系，以根CA为唯一信任顶点，以发卡机构用于签发借记/贷记应用的金融IC卡的CA作为根CA的下级CA。发卡机构用来签发借记/贷记应用的金融IC卡的CA有义务接受根CA的公钥认证服务并成为根CA的下级CA。

发卡机构 CA 可以采用不同方式建设和运行，比如自建并管理或服务外包等，但其系统及运行操作的规范性和安全性应遵从本标准的相关规定。

根 CA 是获得人民银行唯一授权，为我国金融机构提供金融 IC 卡借记/贷记应用公钥认证服务的系统，由中国银联统一管理并由中国金融认证中心(简称 CFCA)运行，其系统和运营安全性符合国家和国际上 EMV 系统的有关安全规范。根 CA 严格按照《中国金融集成电路(IC)卡规范》建设和运行，并与国际标准完全兼容。

4.2 根 CA 公钥认证服务

根 CA 认证服务包含了金融 IC 卡根 CA 业务服务平台：<https://pboc.cfca.com.cn> 和根 CA 系统，金融 IC 卡根 CA 业务服务平台 7*24 小时运行，成员行使用 X.509 证书登陆平台进行业务操作。平台提供成员行机构信息注册、发卡行证书申请、下载根 CA 公钥、统计等功能。

根 CA 系统为离线系统，包含 PBOC2.0 系统和 PBOC3.0 系统，PBOC2.0 系统提供国际密码算法的服务，PBOC3.0 系统目前提供国产密码算法服务，主要包含下列服务：

- 为发卡机构签发发卡机构公钥证书；
- 生成、存储和维护根 CA 公私钥对；
- 将根 CA 公钥证书传递给各成员机构机构。

4.3 生产型公钥证书和测试型公钥证书

IC 卡公钥证书分生产型公钥证书和测试型公钥证书。生产型公钥证书由生产系统产生，测试型公钥证书由测试系统产生。使用 IC 卡进行支付交易时只有使用生产型公私钥对。所有测试型公私钥对和相应的测试型公钥证书仅用于系统测试。

4.4 根 CA 机构角色

4.4.1 根 CA 公钥认证管理机构

中国银联作为根 CA 公钥认证管理机构，负责规范和管理整个根 CA 认证体系的运行，其职责包括制定金融 IC 卡借记/贷记应用公钥认证服务注册流程、根 CA 公钥证书及发卡机构公钥证书发放流程、对金融 IC 卡根 CA 服务平台运营情况进行审核及监督、根 CA 公钥长度及的有效期进行安全评估和调整、制定根 CA 的安全策略并监督其执行情况、对根 CA 和成员机构进行相关审计等。

4.4.2 根 CA 公钥认证运营机构

中国金融认证中心(CFCA)在根 CA 公钥认证管理机构的管理下, 负责根 CA 系统和金融 IC 卡根 CA 服务平台的运营, 包括生成根 CA 公私钥对, 签发、撤销和管理根 CA 公钥证书和发卡机构公钥证书, 进行系统安全操作和管理等。

5 成员机构的公钥认证服务注册及管理

金融 IC 卡根 CA 服务仅向成员机构提供服务。成员机构要接收 CA 公钥证书认证服务必须注册。

5.1 公钥认证服务注册

成员机构进行金融 IC 卡借记/贷记应用公钥认证服务注册的业务流程如下:

1. 获取注册相关材料;
2. 准备注册文件;

5.1.1 注册需要获取的材料

成员机构在有意向进行金融 IC 卡借记/贷记应用公钥认证服务注册时, 可访问中国金融认证中心网站: <http://www.cfca.com.cn> 以获取公钥认证服务注册联系方式及有关资料, 包括:

- 1) 《金融 IC 卡借记/贷记应用根 CA 公钥认证规范》。
- 2) 《成员机构注册及安全管理员证书申请表》。

5.1.2 准备公钥认证服务注册文件

成员机构须确定两名安全员并进行以下准备工作:

- 1) 填写《成员机构注册及安全管理员证书申请表》(见本标准附录 B), 每个成员行必须有两名安全管理员。
- 2) 成员机构本年度和三年内的金融 IC 卡业务计划, 其中发卡机构需提交的内容包括金融 IC 卡发卡计划、拟使用的根 CA 公钥证书、各根 CA 私钥签发的金融 IC 卡的数量、种类以及分布情况; 收单机构需提交金融 IC 卡收单业务计划, 包括其管理的使用根 CA 公钥的终端的数量及分布等。
- 3) 由该成员机构出具的授权书, 证明将该业务授权给所派两个安全员执行;
- 4) 成员机构的两个安全员的有效身份证件;
- 5) 如成员机构委托代理机构进行根 CA 认证业务, 成员机构需出具给代理机构的授权信; 注册所提供的资料必须是本机构的资料。
- 6) 如成员机构委托代理机构处理根 CA 公钥认证业务, 代理机构需要具有国家密码管理局批准的商用密码生产定点单位资质。

进行金融 IC 卡借记/贷记应用公钥认证服务注册时, 其申请应按规定的信息内容与格式, 以书面形式向中国金融认证中心提出, 并确保所提供信息、材料的真实性、准确性。成员机构可就上述文件内容与中国金融认证中心进行沟通, 以保证公钥认证服务注册时提交的资料符合要求。此外, 成员机构需准备缴纳一定的公钥认证服务费。

5.1.3 公钥认证服务注册

成员机构安全员准备好公钥认证服务注册时需要提交的资料, 联系中国金融认证中心客户经理。

中国金融认证中心审核员应根据根 CA 公钥认证管理机构要求, 审核成员行安全管理员信息, 对安全管理员身份、成员行信息、授权信息等注册材料进行审核, 如材料不完整或不真实, 成员机构需重新提交申请材料。注册申请材料需要机构负责人签字并加盖机构公章。

经审核员审核后, 成员机构缴纳公钥认证服务费后, CFCA 将向成员行安全管理员发放登陆“金融 IC 卡根 CA 业务服务平台”的数字证书。成员机构两名安全管理员同时登陆服务平台, 完善成员行注册信息。

成员机构分四种类型: 收单机构、发卡机构、收单发卡机构、金融 IC 卡应用集成服务机构。所有

成员机构注册后可使用金融 IC 卡根 CA 测试系统，收单机构获得中国银联入网测试报告后，可下载生产系统根 CA 证书；发卡机构获得人民银行的批复后可申请签发生产发卡行证书。

5.2 注册管理

成员机构在完成金融 IC 卡借记/贷记应用公钥认证服务注册后，有义务遵守本标准、《中国金融集成电路（IC）卡规范》（JR/T 0025）、《银联卡业务运作规章》。

5.2.1 注册变更

成员机构完成注册后，如需更改公钥认证服务注册材料中的安全员等重要信息时，需要提交变更说明并按照本标准第 5.1 节之规定重新进行公钥认证服务注册。

若因各种原因成员机构需要更改其安全员时，需要提交该机构负责人签署的信件说明，并说明新的安全员的身份及联系方式。变更后的两个安全员将由 CFCA 审核员重新审核后授权。

若发现成员机构未能履行上述义务，则 CFCA 或中国银联有权中止该机构接受公钥认证服务的资格。

5.2.2 退出公钥认证服务

对成员机构退出公钥认证服务的管理如下：

- 1) 接受根 CA 公钥认证服务的成员机构一旦因各种原因决定退出根 CA 公钥认证服务，必须由该成员机构负责人向 CFCA 审核员提交一份手写签名的信函以正式提出退出服务申请；
- 2) CFCA 审核员核实该机构信息后，并向中国银联确认该机构是否存在其他影响，在中国银联的确认下，CFCA 向所有机构颁发该机构的公钥证书撤销信息；
- 3) 若该机构是发卡机构，则该机构必须有效撤销所有已经由 CFCA 撤销的发卡机构公钥证书对应的私钥签发的所有金融 IC 卡，同时该机构有义务承担因用已被撤销的发卡机构公钥证书签发的 IC 卡进行交易而造成的有关损失；
- 4) 若该机构是收单机构，该机构必须确保立即将所有根 CA 公钥移出其所有终端，并从中国银联批准该收单机构退出根 CA 公钥认证服务之日起有义务承担因未将根 CA 公钥撤出其终端而造成的损失。

6 根 CA 公钥证书的管理

根 CA 公钥证书分测试型和生产型，测试型公钥证书仅用于测试，不能部署在正式环境中。

6.1 根 CA 公钥证书的申请、验证流程

根 CA 公钥证书申请、验证业务流程如下：

1. 成员机构安全管理员使用管理员证书登陆金融 IC 卡根 CA 业务服务平台，下载根 CA 公钥证书。
2. 成员机构安全管理员可通过服务平台验证根 CA 公钥证书。

6.1.1 根 CA 公钥证书格式

根 CA 生产型公钥证书以电子版根 CA 公钥文件（见《金融 IC 卡借记/贷记应用根 CA 公钥认证规范 第 2 部分 技术规范》第 6 章）形式传递。

6.1.2 成员机构需要申请的根 CA 生产型公钥个数

发卡机构应按照本标准第 7.2.1.2 节之规定申请相适应的根 CA 公钥，收单机构应申请所有的根 CA 公钥。

6.1.3 根 CA 生产型公钥的验证

成员机构安全员在收到根 CA 公钥证书后，应按照《金融 IC 卡借记/贷记应用根 CA 公钥认证规范 第 2 部分 技术规范》第 7 章的规定验证根 CA 公钥，根 CA 公钥验证成功后方可以接受并使用。

6.2 收单机构根 CA 生产型公钥证书的放置、移出

收单机构必须按照本标准第 6.1 节规定程序获取并成功验证根 CA 公钥才可以使用它们。收单机构负责将所有中国银联当前使用的根 CA 公钥信息按照本标准第 8.4.1 节规定的时间内安全放置在支持

银联金融 IC 卡支付业务（支持 SDA、DDA、或 CDA）的所有终端并维持其有效性，并将过期的根 CA 公钥信息按照本标准第 8.4.2 节规定的时间内移出所有终端并废除。

6.2.1 装载根 CA 公钥信息

收单机构必须按照《中国金融集成电路（IC）卡规范》（JR/T 0025）和中国银联《银联卡业务运作规章》将根 CA 公钥信息装载在其所有支持银联金融 IC 卡支付交易（SDA、DDA、CDA）的终端中。

6.2.2 将根 CA 公钥信息传递给终端

为了确保收单机构将收到并验证的根 CA 公钥信息安全地传递到终端，收单机构必须遵守下列规则：

1. 在根 CA 公钥由收单机构传递给终端时，终端设备必须验证传输的公钥信息的数据完整性并进行信息源认证，比如在传输过程中使用数字签名或使用 MAC 认证码。收单机构可以选择授权机构管理部分终端。授权机构可以是与一个收单机构有业务协议并管理一部分终端或终端的接收数据装置，或一个与收单机构有相关业务协议授权的机构负责维护管理部分终端或终端数据接收装置。根 CA 公钥在由收单机构传输到授权机构过程中，必须验证传输的公钥信息的数据完整性和进行信息源认证。根 CA 公钥由授权机构传输到终端也必须验证传输的公钥信息的数据完整性和信息源认证。终端数据接受装置在接收根 CA 公钥数据，或由人工控制过程中，必须进行有效的访问控制。
2. 验证过的根 CA 公钥在传输到终端过程中，必须保证数据完整性。这个规则确保终端收到的验证过的根 CA 公钥数据是完整的。比如验证公钥信息的哈希值，或实施有效的校验和验证。
3. 确保新引入的根 CA 公钥信息在公钥生效日期前装载到每个终端。必须确保新引入的根 CA 公钥在使用该根 CA 公钥的金融 IC 卡的流通日期前装载到每个终端，以便保证使用该根 CA 公钥的金融 IC 卡在其生效时即可使用。收单机构对这个要求必须能够审计。
4. 确保到期或撤销的根 CA 公钥在到期或撤销的 6 个月内移出每个终端或停止在终端使用。终端能够鉴别过期或已撤销的根 CA 公钥。收单机构对这个要求必须能够审计。
5. 收单机构必须能够在合理的时间期限内确认在其每个终端，哪些 IC 卡支付系统根 CA 公钥正在使用。
6. 收单机构必须能够报告其每一个终端当前能够支持的密钥长度。其当前支持的密钥长度必须保持与中国银联公布的所有在生效期内的根 CA 公钥长度同步，以便支持在银联金融 IC 卡公钥体系内的所有 IC 卡的使用。同时，终端必须有效防止使用过期根 CA 密钥的金融欺诈。

6.2.3 根 CA 公钥的移出

6.2.4 到期的根 CA 公钥

中国银联的基于《中国金融集成电路（IC）卡规范》（JR/T 0025）的风险管理周期性地评估和确认根 CA 公钥的失效日期（见本标准第 8.2 节）。收单机构的密钥管理必须基于根 CA 公钥失效日期将过期的根 CA 公钥移出所有终端。

—— 中国银联将在每个根 CA 公钥有效期到期的 6 个月之前提前以信件方式通知成员机构其特定的根 CA 公钥将要到期。

—— 收单机构必须确保根 CA 公钥在有效期到期后的 6 个月内移出其全部的终端。

6.2.5 提前撤销的根 CA 公钥

中国银联将分析确认由于针对密钥的攻击，一对根 CA 公钥是否需要提前撤销。一旦发生这种事件，中国银联将结果和应采取的措施通知所有接受根 CA 公钥认证服务的成员机构。见本标准第 8.2.5 节。

7 发卡机构公钥证书的管理

7.1 发卡机构公钥证书申请、传递、验证

成员机构在完成金融 IC 卡借记/贷记应用公钥认证服务注册后即可申请发卡机构测试型公钥证书，但是必须先按照本标准第 6.1 节的规定获取和验证相应（与签发发卡机构测试型公钥证书私钥对应的）根 CA 测试型公钥证书。

发卡行CA公钥证书的申请、传递及验证业务流程如下：

1. 成员机构安全管理员使用管理员证书登陆金融IC卡根CA服务平台，通过平台申请发卡行证书记录号；系统将根据中国银联设置的检查规则，自动校验申请信息的正确性，如校验不能通过将进入待审核状态，银联审核员将人工审核成员行申请信息。
2. 申请信息审核通过后，CFCA操作员在金融IC卡根CA系统执行操作，并将记录号反馈给成员行安全管理员。
3. 成员行安全管理员利用该记录号生成发卡行证书申请文件，并登陆金融IC卡根CA服务平台申请签发发卡行证书。服务平台将验证申请文件的有效性。CFCA操作员处理该申请后将申请结果反馈给成员行安全管理员。
4. 成员行安全管理员获得发卡行证书后，应对证书进行确认验证，成员机构安全管理员可在服务平台验证发卡行公钥证书，已下载证书2个工作日没有反馈，视为验证通过。

7.2 发卡机构公钥证书申请前的准备

根 CA 使用标准工作程序受理发卡机构公钥证书申请，对包括发卡机构公钥证书申请的准备、申请书数据格式、命名规则等方面的业务作了明确规定。发卡机构在决定申请发卡机构公钥证书时必须遵循下列规则。

7.2.1 角色分离原则

为了有效控制对发卡机构公钥证书申请的关键数据错误的风险，中国银联规定发卡机构公钥证书的申请操作必须由两个安全管理员同时完成。

7.2.2 发卡机构公钥的业务决策

在向中国银联申请发卡机构公钥证书前，每个发卡机构必须做下列决策，每一决策在业务和安全上都有不同影响，因此发卡机构必须在决策时仔细评估由其导致的风险和代价。发卡机构业务决策包括：

- 1) 需要生成的发卡机构公私钥对个数，即需要申请的发卡机构公钥证书个数。参见本标准第 8.3.2 节。
- 2) 每对公钥的密钥长度，发卡机构公钥长度必须小于或等于用来签发该发卡机构公钥证书的根 CA 公钥长度。见本标准第 8.2.1 节。
- 3) 发卡机构每对公钥的失效日期，发卡机构公钥失效日期必须早于或等于用来签发该发卡机构公钥证书的根 CA 签名公私钥对的失效日期。此外，对于由一对发卡机构公钥签发的具有 IC 卡公私钥对的 IC 卡（支持动态卡数据认证），该 IC 卡公钥的失效日期必须早于或等于发卡机构的这对公钥的失效日期。因此，IC 卡的失效日期必须早于或等于用于签发该 IC 卡（卡内静态数据或 IC 卡公钥证书）的发卡机构公钥的失效日期。并且若 IC 卡具有 IC 卡公钥证书，IC 卡的失效日期必须早于或等于该 IC 卡公钥失效日期。根 CA 公私钥对的失效日期参见本标准第 8.2.1 节。
- 4) 发卡机构使用 RSA 公钥对时，每一对公钥的公钥指数必须是 3 或 $2^{16}+1$ 。
- 5) 发卡机构可以有多个发卡机构公钥证书，但是只能将签发该 IC 卡的发卡机构公钥证书放入该 IC 卡。

在发卡机构完成了上述业务决策后即可进行发卡机构公钥证书的申请。

7.2.3 发卡机构公钥证书申请书的准备

- 1) 发卡行证书将以 BIN 号和记录号唯一表述，因此发卡机构产生公钥证书申请文件时需要先申

请记录号；一个 BIN 号只能属于一个发卡机构所有，一个发卡机构的一个 BIN 号可以申请多个记录号和发卡行证书。

- 2) 发卡机构使用已申请的记录号、发卡机构公私钥对生成发卡机构公钥输入文件。发卡机构公钥输入文件格式参见《金融 IC 卡借记/贷记应用根 CA 公钥认证规范第 2 部分 技术规范》第 8 章。

根 CA 对发卡机构公钥证书申请的受理

中国银联对发卡机构公钥申请的审批程序如下：

- 1) 发卡行安全管理员登陆“金融 IC 卡根 CA 业务服务平台”，提交发卡行证书申请。
- 2) CFCA 操作员收到平台通知后，在根 CA 系统执行证书签发，并将签发的证书分发给服务平台；
- 3) 发卡行安全管理员收到通知后，登陆服务平台下载已签发的发卡行公钥证书。

发卡行安全管理员验证下载的发卡行公钥证书，验证通过后方能使用。

7.3 发卡机构对根 CA 签发的公钥证书的验证与接受

发卡机构在收到根 CA 签发的发卡机构公钥证书后，必须按照《金融 IC 卡借记/贷记应用根 CA 公钥认证规范第 2 部分 技术规范》第 11 章的规定程序验证发卡机构公钥证书的签名以确认收到的证书的信息完整性和进行信息源的认证。

7.4 发卡机构公钥信息变更管理

一旦发生因发卡机构业务、机构、人员变动出现的需要变更公钥证书的需求，发卡机构必须按照本标准的程序重新向中国银联申请发卡机构公钥证书，同时根 CA 将发卡机构原有证书撤销。

7.4.1 发卡机构公钥证书的更新

在发卡机构公钥证书到期时，按照本标准第 7.2 节程序重新申请一个新的发卡机构公钥证书。发卡机构有义务承担因使用过期的发卡机构公钥证书而导致的金融 IC 卡交易而造成的损失。

7.4.2 发卡机构公钥证书的提前撤销

在发卡机构决定将一个发卡机构公钥证书提前撤销（在失效日期前）时，发卡机构安全员登陆服务平台申请撤销发卡机构公钥证书的记录号和银行卡 BIN 以及要求撤销生效的日期。

CFCA 操作员收到申请通知后，按照发卡行指定日期将相应的发卡机构公钥证书撤销，并反馈撤销结果。

发卡机构有义务承担因使用被撤销的发卡机构公钥证书签发的 IC 卡进行支付而造成的损失。

8 根 CA 公钥认证体系安全策略的安全规则

根 CA 公钥认证体系安全策略包括基本条款和安全规则两部分内容。根 CA 公钥认证体系安全策略的基本条款见本标准附录 A。

安全规则分为三个层面，中国银联和成员机构必须遵循《中国金融集成电路（IC）卡规范》（JR/T 0025）的第七部分关于安全的规则。这三个层面是：

- 1) 一般规则：适用于中国银联和成员机构。
- 2) 根 CA 规则：适用于银联金融 IC 卡支付业务。
- 3) 用户规则：适用于发卡机构和收单机构。

8.1 一般规则

一般规则适用于中国银联和所有成员机构。

8.1.1 密钥安全

中国银联和成员机构在生成其自身的非对称公私钥对时有责任确保：

- 1) 采用安全的方式生成自身的公私钥对，公私钥对必须在符合国家密码管理局相关规定的密码硬件中产生。

- 2) 保护私钥以防止密钥泄漏并确保私钥的完整性, 签名私钥必须始终处于符合国家密码管理局相关规定的密码硬件中。
- 3) 保护公钥的完整性。
- 4) 在分发和传递过程中保护公钥的完整性。

银联金融 IC 卡支付体系的安全在很大程度上取决于各级公私钥对或密钥在其整个生命周期内的安全管理。根 CA 和发卡机构必须严格按照《中国金融集成电路 (IC) 卡规范》(JR/T 0025)、中国银联《银联卡业务运作规章》和本标准进行包括在其业务范围内的各级公私钥对、密钥的安全生成、处理、分发、注销的管理。由于根 CA 公钥证书及发卡机构公钥证书及其相应公私钥对是用来生成在金融交易中实际使用的金融 IC 卡, 因此根 CA 和发卡机构必须对其证书对应的公私钥对进行严格的密钥管理, 其证书公私钥对对应的私钥必须始终处于密码硬件中, 或在多人控制下进行加密备份, 备份的私钥必须始终处于国密局规定的密码硬件中。

成员机构在取得根 CA 公钥证书后必须验证它的签名才可使用, 成员机构在存储, 分发根 CA 公钥时必须确保数据完整性和信息源的可认证性。

发卡机构在获取根 CA 为其签发的发卡机构公钥证书后必须验证证书的签名才可使用, 在存储, 分发发卡机构公钥证书时必须确保数据完整性和信息源的可认证性。

8.1.2 审计和控制

中国银联和成员机构必须采用审计和控制手段以增强使用和管理根 CA 公钥证书服务过程的安全性和有效性。

中国银联保留对成员机构审计的权利以确认发卡机构的操作符合相关要求。

发卡机构需要在每年 12 月 20 日前通过银联审核员向中国银联提交一份其使用根 CA 公钥认证服务报告, 内容包括该发卡机构使用那些发卡机构公钥证书对应的私钥签发了多少张银联标准 IC 卡、卡的业务种类和发卡地域, 以及下一年度签发银联标准 IC 卡的业务计划, 同时报告需要针对《中国金融集成电路 (IC) 卡规范》(JR/T 0025)、《银联卡业务运作规章》和本标准的相关规定阐述本机构的相关措施和运行操作。同时中国银联有权利对发卡机构进行审计, 审计内容包括发卡机构的操作运行与《中国金融集成电路 (IC) 卡规范》(JR/T 0025)、《银联卡业务运作规章》和本标准相关规定的吻合度。

收单机构需在每年 12 月 20 日前通过银联审核员向中国银联提交一份由该收单机构管理的终端中使用的根 CA 公钥的报告, 包括终端数量、各自使用那些根 CA 公钥、分布情况、运行情况等, 以及一年度进行银联标准 IC 卡收单业务的业务计划, 同时报告需要针对《中国金融集成电路 (IC) 卡规范》(JR/T 0025)、《银联卡业务运作规章》和本标准的相关规定阐述本机构的相关措施和运行操作。同时中国银联有权利对收单机构进行审计, 审计内容包括收单机构的操作运行与《中国金融集成电路 (IC) 卡规范》(JR/T 0025)、《银联卡业务运作规章》和本标准相关规定的吻合度。

8.1.3 错误检测

中国银联和成员机构必须采用错误检测服务以监测相关系统并快速确认任何可能的根 CA 密钥泄漏或发卡机构密钥泄漏。根 CA 和成员机构必须在需要时执行紧急恢复计划。

8.2 根 CA 规则

8.2.1 根 CA 系统公私钥对规则

8.2.1.1 根 CA 公私钥对基本要求

中国银联规定了银联 IC 卡支付系统关于公私钥对的下列规定:

- 1) 针对一个 RID 使用的根 CA 公钥最大个数为 6 个。
- 2) 支付系统支持 RSA、SM2 公钥密码算法。
- 3) 支付系统公钥的失效日期为规定年份的 12 月 31 日。

银联 IC 卡支付系统密钥参数的选定是基于下列因素:

- 1) 基于密码学界对于公钥密码算法安全的专业知识以确认使用系统安全的参数。其目标是确保

使用当前已知技术的密码攻击无法在实际上破解系统所使用的密钥。

- 2) IC 卡存储和处理能力。
- 3) 支付终端公钥认证的处理能力。
- 4) 将支付终端需要处理的公钥数目降低到最小。
- 5) 为发卡机构根据其颁发的 IC 卡能力和安全要求提供密钥可选范围。

8.2.1.2 根 CA 密钥方案

中国银联将对金融 IC 卡根 CA 公钥的有效期做周期性评估和调整。最新的公钥方案及有效期公告参见银联官网“业务园地”的“业务动态”板块；CFCA 也将在金融 IC 卡根 CA 业务服务平台上公布根 CA 的最新有效期。

基于本标准第 6.2.1 节的安全性规则，根 CA 使用最新方案的公私钥对长度及有效期。

发卡机构应确保由其颁发的金融 IC 卡在该 IC 卡有效期内，其对应的 IC 卡公钥证书（若支持 DDA）、发卡机构公钥证书及相关的根 CA 公钥是有效的。

8.2.2 重新评估金融 IC 卡支付系统密钥安全性

中国银联在每一年都将对银联金融 IC 卡公钥支付系统中密钥的长度及其安全性做一评估。这项评估以本标准第 8.2.1.1 节所述安全因素，并以密码界的任何有关新的进展为基础。同时，安全性评估也将借鉴 EMV 的年度签名密钥长度安全评估结论。对评估结果，中国银联将报备于中国人民银行。中国银联将在每年底前发布对公钥密码算法的安全评估结论和对当前使用的根 CA 密钥的有效期及相关的任何调整。

8.2.3 现有根 CA 密钥长度安全性（有效期）的延伸

除了每年一度的根 CA 密钥长度安全性的评估，中国银联也将根据该评估结果决定当前正在使用的根 CA 公私钥对有效期的延伸。任何这样的变更将会由银联“安全通告”发布。

8.2.4 新的根 CA 公私钥对的引入

在计划的根 CA 公私钥对有效期到期时，中国银联将常规地引入新的根 CA 公私钥对以取代到期的公私钥对。同时根据银联 IC 卡支付系统公钥安全年度评估报告，中国银联也会决定引入新的根 CA 公私钥对。

在中国银联决定引入新的根 CA 公私钥对时，必须遵守下述规则：

- 1) 新的根 CA 公私钥对总是在有效期到期当年的 12 月 31 日废除。
- 2) 中国银联将在新的根 CA 公私钥对生效年份的前一年的 10 月 31 日前将新引入的根 CA 公私钥对发布在“安全通告”中。
- 3) 中国银联将确保各个成员机构在新的根 CA 公私钥对生效年份的前一年的 12 月 31 日前收到新引入的根 CA 公私钥对。
- 4) 收单机构必须确保由其拥有的所有终端在新引入的根 CA 公私钥对生效当年的 6 月 30 日前布置好新引入的根 CA 公钥。
- 5) 中国银联将在新引入的根 CA 公私钥对生效年份的 1 月 1 日开始用新的根 CA 密钥签发发卡机构公钥证书。
- 6) 发卡机构必须确保所有使用相应的新的发卡机构公私钥对颁发的金融 IC 卡的生效期不早于新的根 CA 公私钥对生效年份的 6 月 30 日。

8.2.5 根 CA 公私钥对的提前撤销

根 CA 公私钥对的提前撤销是指在根 CA 公私钥对有效期到期之前将根 CA 公私钥对撤销。根 CA 公私钥对的提前撤销是当新的密码分析技术威胁到现有密钥长度的密钥的安全性，或怀疑根 CA 公私钥对失密，或因其它原因使得继续使用当前的根 CA 公私钥对会造成可能的严重安全隐患，或无法继续使用当前的根 CA 公私钥对时进行的。

基于根 CA 公私钥对的提前撤销对金融 IC 卡系统及其业务会造成冲击，根 CA 将鉴别下列密钥失

密的类型:

—— 怀疑的密钥失密

- 当密码分析技术取得突破性进展或针对 IC 卡支付系统使用的签名算法的具体攻击方式取得突破性进展时, 实际发生密钥失密的可能性急剧加大;
- 基于实际发生的欺诈性交易, 现实意外事件隐含的威胁, 公布的或怀疑的欺诈, 可以怀疑根 CA 签名私钥已经失密。

—— 证实的密钥失密

- 中国银联已经收到证据, 基于密码界对根 CA 所使用的签名算法的分析和攻击取得突破性进展, 显示根 CA 私钥已经失密, 或将会在该公私钥对的有效期到期之前失密。
- 中国银联已经确认下列两种对根 CA 密钥的有效攻击, 两者都能够实际破解根 CA 私钥:
 - ◆ 非恶意攻击: 攻击者并非卷入金融犯罪但会公布其破译方法和结果, 其结果将导致实际的根 CA 私钥的破译。
 - ◆ 恶意攻击: 攻击者实际掌握了对根 CA 私钥的有效攻击手段并将卷入金融犯罪。

这两种密钥失密都将导致根 CA 密钥的提前撤销。

8.2.6 根 CA 公私钥的废除

一旦决定需要将当前使用的根 CA 公私钥对废除, 根 CA 将立即停止使用失密的根 CA 签名私钥签发发卡机构公钥证书, 同时中国银联将于当天即将事件通知各有关成员机构。

中国银联将联合各个发卡机构和收单机构以确认由于废除当前使用的根 CA 公私钥对而带来的金融业务冲击, 包括进行风险评估。风险评估包括:

- 1) 长度更长的公私钥对交易时间和 IC 卡存储性能的影响。
- 2) 对正在使用的 IC 卡和终端的影响。
- 3) 由之导致的或潜在的欺诈风险。
- 4) 对金融 IC 卡业务或技术的冲击。
- 5) 对银联品牌在国内或国际的影响以及加固银联品牌、加固中国银联与合作方关系的战略。
- 6) 相关的法律专家确定各方的责任与义务并与中国银联相关的国内或国际业务合作方进行合作。
- 7) 中国银联进行包括涉及法律法规方面在内的安全和安全风险管理和增强。

中国银联将遵循下列程序以获得对一个正在使用的根 CA 公私钥对的撤销:

- 1) 对上述业务风险和安全风险评估结果进行分析。
- 2) 完成一份撤销具有风险的根 CA 公私钥对的建议书。
- 3) 中国银联对建议书审核批准。
- 4) 将批准后的建议书递交给中国人民银行备案。
- 5) 根 CA 按照《中国金融集成电路 (IC) 卡规范》(JR/T 0025) 第七部分的第十章规则撤销受到影响的根 CA 公私钥对。

8.3 发卡机构规则

8.3.1 密钥周期

发卡机构在生成发卡机构公钥时必须确定该公钥的失效日期。

发卡机构公钥失效日期必须早于或等于用来签发该发卡机构公钥证书的根 CA 公私钥对的失效日期。同时发卡机构必须确保使用它的一个发卡机构公私钥对签发的 IC 卡的失效日期不晚于这个发卡机构公钥的失效日期。

8.3.2 发卡成员机构的公私钥对个数

中国银联不限制发卡机构使用的发卡机构公私钥对个数, 因为发卡机构公私钥对的个数并不影响终端对一张 IC 卡的认证。这样发卡机构可以根据其业务需求选择使用一个或多个发卡机构公私钥对进行它的发卡业务, 需要考虑的因素有每一类 IC 卡产品、持卡人所在区域等。然而, 为安全性考虑, 中

国银联建议发卡机构按照它的发卡业务，根据发卡机构标识代码（BIN）来申请发卡机构公钥证书，并使用不同的发卡机构公私钥对来对具有不同 BIN 号的 IC 卡进行发卡业务。这种方式能在发生发卡机构签名私钥失密时更有效地控制安全和业务风险。这样，中国银联要求发卡机构的公钥证书申请中包括 BIN 号。

8.4 收单机构规则

8.4.1 引入新的根 CA 公私钥对

见本标准第 8.2.4 节。

8.4.2 撤销一对根 CA 公钥

收单机构必须确保其拥有的所有终端在一个根 CA 公私钥对失效日期后的 6 个月内将该公钥移出终端并将其废除。

附 录 A (规范性附录)

金融 IC 卡借记/贷记应用根 CA 安全策略的基本条款

A.1 责任与义务

A.1.1 银联公钥认证管理机构责任和义务

中国银联应该承担的责任和义务：

- a) 规范中国银联金融 IC 卡支付产品和服务的系统规则，并验证所采用的产品与这些规则相一致。
- b) 运行和管理根 CA 公钥认证服务，其中包括向发卡机构签发发卡机构公钥证书，传递根 CA 公钥信息的根 CA 公钥认证服务，规范根 CA 系统设置、密码算法和密钥的使用等。
- c) 审查各个成员机构系统的安全性和规范性。
- d) 审查支付体系各个环节符合国家有关政策的规定。
- e) 将根 CA 公钥的变更以及时间安排通知给成员机构。

A.1.2 根CA责任和义务

根 CA 应该承担的责任和义务为：

- 安全管理根 CA 系统的签名公、私钥对。
- 向发卡机构签发发卡机构公钥证书。
- 安全管理根 CA 公钥信息向发卡机构和收单机构的传递。
- 安全管理根 CA 与发卡机构之间的发卡机构公钥及其公钥证书的传递。

A.1.3 发卡机构CA责任和义务

- 安全生成金融 IC 卡借记/贷记应用所需的密钥，包括发卡机构自身的签名公、私钥对并向根 CA 申请发卡机构公钥证书，安全生成由其颁发的银联金融 IC 卡个人化所需的密钥，并颁发银联金融 IC 卡。
- 接收、验证由根 CA 提供的根 CA 公钥信息，并保护其信息完整性。
- 为生成由其颁发的银联金融 IC 卡公钥证书和签名数据运行并维护发卡机构自身的密钥管理系统。
- 维护其发卡机构公私钥对整个生命周期内的安全性。
- 以其自身生成的发卡机构公钥向根 CA 申请发卡机构公钥证书；接收、验证由根 CA 签发的发卡机构公钥证书。

A.1.4 收单机构责任和义务

收单机构有责任与义务确保：

- 接收、验证、安全存储根 CA 的所有公钥；
- 以安全方式将验证过的所有根 CA 公钥布放在所管理的所有终端；
- 在将根 CA 公钥传递给终端的过程中保证信息完整性和信息源的可认证性；
- 在收到根 CA 公钥信息时需安全地在规定时间内安装在其所有支付终端，并将过期的根 CA 公钥规定时间内撤出所有由其管理的终端。见《中国金融集成电路（IC）卡规范》（JR/T 0025）第七部分的安全策略。

A.2 免责和理赔

- 如果证书申请者故意或无意地提供不完整、不可靠或已过期的信息，而他又根据正常的流程提供了必须的审核文件，由此得到了根 CA 签发的公钥证书。由此引起的经济纠纷应由申请者

全部承担，中国银联不承担与证书内容相关的法律和经济责任。

- 中国银联在法律许可的范围内，根据受害者或法律的要求如实提供电子交易和作业中“不可抵赖”的数字签名依据，但并不对此承担法律责任。
- 在中国银联遵守本规范的前提下，中国银联不对任何一方在信赖证书或使用证书过程中，由于成员机构、持卡人或商户原因引起的交易双方直接或间接的损失承担责任。
- 理赔的限制。在中国银联违反了本标准第 A.1 节规定的职责，中国银联承担赔偿责任（法律免责除外）。赔偿限制如下：（1）中国银联所有的赔偿义务不得高于这种证书适用的债务上限，这种上限可以由中国银联改动。（2）中国银联只有在证书有效期内承担这种损失或损害赔偿。
- 在中国银联遵守本规范的前提下，中国银联没有义务接受由于根 CA 签名密钥泄漏造成的成员机构声称的赔偿。

A.3 信任体的责任关系

A.3.1 证书依赖方和证书持有者的赔偿责任

1. 证书依赖方和证书持有者在使用或信赖证书时，若有任何行为或疏漏而致使中国银联产生损失，证书依赖方和证书持有者应承担赔偿的责任、相应的损失及诉讼等费用。中国银联有权要求赔偿。
2. 证书持有者的责任并不仅限于本标准的规定，证书持有者如果向第三方传递信息时表述有误，而第三方用证书验证了一个或多个数字签名后理所当然地相信这些表述，证书持有者必须对这种行为的后果负责。
3. 证书持有者接受证书就表示同意在以下情况下承担赔偿责任：
 - 证书持有者（或者按照证书持有者授权人的指示行事的人）对事实表达有误或曲解时；
 - 证书持有者没有公开一项实质性的事实，而且造成这种错误或遗漏的原因是出于他的疏忽或是他有意欺瞒中国银联时；
 - 未能保护证书持有者的私钥，或者没有使用必要的防护措施来防止证书持有者的私钥遗失、泄密、被修改或被未经授权的人使用时。
4. 当一个证书应证书持有者的代理人要求被签发后，代理人 and 证书持有者两者负有连带责任。如出现上述条款 3) 的情况，他们共同赔偿。证书持有者有责任就代理人所作任何不实陈述与遗漏通知中国银联。

A.3.2 信托关系

中国银联不是证书持有者或依赖方的代理人、受托人、管理人或其他代表。中国银联和证书持有者间的关系以及中国银联和证书依赖方间的关系并不是代理人和委托者的关系。证书持有者和证书依赖方都没有权利以合同形式或其他方法让中国银联承担信托责任。

A.4 解释和说明

A.4.1 监管法律

本标准在各方面服从国家法律的管制和解释。

A.4.2 争端解决的程序

如果当事人之间无法很好的解决出现的问题和争端，应该提交仲裁机构，根据仲裁条例在时效内裁决。这些条例在本标准中已经体现和规定了。仲裁的决定是终决性的，对每个当事人都有约束力。仲裁的议程应采用中文记录，而且仲裁决定应由有司法权的法院来判定，或者申请法院对其判决或执行命令时予以司法许可范围内的配合。

A.5 审计

A. 5.1 对根CA的审计

由中国银联或法律主管部门指定审计者。审计者对中国银联的根 CA 进行审计。中国银联本身也需要对根 CA 的关联单位所有的流程和操作进行审计，检验其是否符合本标准和相应策略的规定。其频率由中国银联决定或由法律制定的监管机构决定。

A. 5.2 对成员机构的审计

对成员机构的审计见本标准第 8.1.2 节。

A. 5.3 审计者的资质

对借记/贷记应用根 CA 和成员机构实施规范审计的审计者所具有的资质和经验必须符合监管法律和行业准则规定的要求，包括：

- 1) 必须是经许可的、有营业执照的公共会计师或是经许可的商业评估机构，在业界享有良好的声誉；
- 2) 了解计算机信息安全体系、通信网络安全要求、PKI 技术和操作；
- 3) 熟悉金融 IC 卡业务，了解中国金融 IC 卡相关的规范和标准；
- 4) 具备检查系统运行性能的专业技术和工具。

A. 5.4 审计者与被审计机构的关系

审计者必须是一个独立于被审计机构的实体。

A. 5.5 审计的主要内容

对根 CA 规范审计应包括：

- 1) 根 CA 支持的证书认证操作规程是否完整地在本标准、《金融 IC 卡借记/贷记应用根 CA 系统公钥认证技术规范》、《中国金融集成电路（IC）卡规范》（JR/T 0025）和相关运行策略中表达，包括根 CA 的技术、手续和员工的相关管理政策和操作规范。
- 2) 根 CA 是否实施了相关的技术、管理、相关政策和操作规范。

对成员机构的审计主要内容见本标准第 8.1.2 节。

A. 5.6 对不足的处理

如果在对金融 IC 卡借记/贷记应用根审计过程中发现执行规范有不足之处，中国银联将根据审计报告的内容准备一份解决方案的报告来明确对此采取相应的行动。中国银联将根据普遍认可的国际惯例或监管法律以最快的速度来解决问题。

如果在对成员机构审计过程中发现执行规范有不足之处，成员机构将根据审计报告的内容准备一份解决方案的报告来明确对此采取相应的行动。成员机构将根据普遍认可的国际惯例或监管法律以最快的速度来解决问题。

A. 5.7 审计结果

除非法律明确要求，中国银联一般不公开审计的结果。在必要的情况下，对中国银联关联单位通知审计结果的详情和具体方法将在中国银联和另一方各自的协议中写明。

A. 6 保密

A. 6.1 保密信息

- 1) 保密信息包括中国银联与成员机构及相关第三方服务提供机构、中国银联与证书持有者间的协议、往来函和商务协定等。除非法律明确规定，一般不能在未经另一方许可的前提下擅自公开。
- 2) 与证书持有者证书公钥配对的私钥是保密的，证书持有者应该认真保管，不能公布给他人。如果证书持有者擅自泄露私钥，则由此引起的后果由证书持有者自负。
- 3) 对中国银联或中国银联对成员机构和相关第三方服务机构的审计报告、审计结果等相关信息是保密信息，除了中国银联授权和信任的员工，不能泄露给其他任何人。这些信息除了审查目的或法律规定的目的，不能用于其他用途。

4) 有关中国银联机构的运作信息只能在严格指定的情况下,才能传授给经中国银联授权的员工。

5) 除非法律明文规定,中国银联没有义务公布或透露证书持有者证书以外的信息。

A. 6. 2 非保密信息

与证书有关的申请流程、申请需要的手续、申请操作指南等书中公布的信息是可以公开的。而且中国银联在处理申请业务时可以利用这些信息,包括发布上述信息给第三方。

A. 6. 3 证书被废除/暂停使用的信息披露

中国银联在中国银联的根 CA 发布服务器中公布证书的废除信息,供网上查询。

A. 6. 4 向法律执行机关披露

当中国银联在任何法律、规章或法规条款的要求下,或在法院的要求下必须披露本标准中具有保密性质的信息时,中国银联可以按照法律、法规、或法规条令以及法院判决的要求,向执法部门公布相关的保密信息。中国银联无须承担任何责任。这种披露不能视为违反了保密的要求和义务。

A. 6. 5 根据所有者的要求披露信息

当保密信息的所有者出于某种原因,要求中国银联公开或披露他所拥有的保密信息,中国银联应满足其要求。如果这种披露保密的行为涉及任何其他方的赔偿义务,中国银联不应承担任何于此相关的或由于公开保密信息所造成的损失。保密信息的所有者应负责中国银联与此相关的或由于公开保密信息引起的所有损失、损坏的赔偿责任。

附 录 B
成员机构注册及安全管理员证书申请表

表 B.1 成员机构注册及安全管理员证书申请表

证书申请信息					
申请日期		证书数量		证书期限	
业务类型	☐ 新申请 ☐ 更新 ☐ 吊销		证书用途	金融 IC 根 CA 业务	
证书 DN	(仅更新或吊销时填写)				
申请机构信息					
机构名称					
入网机构标识码					
机构证件类型	☐ 企业营业执照 ☐ 组织机构代码证 ☐ 其它，请注明：				
机构证件号码					
机构经办人信息					
安全管理员 1 姓名		电话		邮箱	
安全管理员 1 证件号码					
安全管理员 2 姓名				邮箱	
安全管理员 2 证件号码					
成员机构审批人姓名		电话		邮件	
联系地址				邮政编码	
申请机构声明					
本机构承诺以上信息资料真实、有效。本机构已认真阅读并同意遵守中金金融认证中心有限公司（CFCA）网站（ http://www.cfca.com.cn ）发布的《数字证书服务协议》、《电子认证业务规则（CPS）》中规定的相关义务。					
申请机构盖章				日期	
备注					

注：本表需加盖申请机构公章。申请机构须同时提供机构证件复印件（加盖公章）、安全管理员身份证件复印件、机构授予经办人的授权书原件。

表 B.2 授 权 书

☐ 我单位授权我单位下列人员：_____身份证号：_____代表我单位与中国银联和 CFCA 进行金融 IC 卡借记/贷记应用公钥认证服务的注册，并授权这两个职工作为安全员代表我单位作为今后与银联就金融 IC 卡公钥认证业务的授权联系人。注册成功后，我单位将遵守“金融 IC 卡借记/贷记应用根 CA 公钥认证管理规则”规定的银联成员机构的责任与义务的规定，并为我单位安全员的行为负责。

单位名称：（公章）
日期：

表 B.3 授 权 书

☐ 我单位授权_____机构作为我单位接受金融 IC 卡借记/贷记应用公钥认证服务的代理机构，并授权_____机构的下列人员：_____身份证号_____作为安全员代表我单位作为今后与银联就金融 IC 卡公钥认证业务的授权联系人。注册成功后，我单位将遵守“金融 IC 卡借记/贷记应用根 CA 公钥认证管理规则”规定的银联成员机构的责任与义务的规定，并为_____机构的行为负责。

单位名称：（公章）
日期：
